BrowserOS-KaihongOS

1:1 复刻代码级审计与开发推进方案

审计基线：2026-10-27（Asia/Taipei）

深开鸿 HEAD	d98d48da33d1782b3dc24f07c83e58012d13868b
上游 BrowserOS HEAD	10caad1d8d575cafe765b8e94e95f51ef0a4a744
主要对标产品	BrowserOS neo；BrowserOS main 单独标记
审计边界	源码/仓库证据复核；本次未独立 build HAP 或重跑物理设备 E2E

1. 管理摘要

结论：深开鸿版已具备真实 ArkWeb 浏览器和多项 AI 浏览器功能，不再是早期占位原型；但当前代码证据不足以支持“对上游 main 全功能 1:1”。当前最主要的工作从补 UI 转为 MCP 语义/会话隔离、Harness 真安装、登录态迁移、回放、密码库安全和测试门禁。

- 高优先级一：ConnectionManager.checkToolInstalled() 固定返回 false；writeMCPConfig() 写 App 沙盒文件而非 harness 配置文件。MCP 安装板可以生成/复制 JSON，但不等于一键安装。
- 高优先级二：McpJsonRpcCore 协议版本写死 2024-11-05；上游 MCP server 当前显式支持 2026-07-28 与 legacy versions。17 个工具名称匹配不等于协议和行为匹配。
- 高优先级三：upload/pdf 明确 unsupported、windows 只 list、tab_groups 最小实现；act.ref 以 CSS selector 为准，需与上游 snapshot 的稳定引用语义对齐。
- 高优先级四：MCP initialize 回传 session id 但缺少后续 session-to-tab ownership/profile target 的完整关联，外部并发 harness 隔离风险高。
- 高优先级五：Chrome profile 路径/读取 cookie/localStorage 的函数是 stub；会话回放以定时截图为主；不等于上游 rrweb 页状态回放。
- 安全红线：CredentialStore 主路径把 JSON 凭据数组写入 Preferences；Bitwarden 导出标记 encrypted:false；AgentEngine 操作日志可能写入 type/fill 的原始参数。
- 工程红线：README/CHANGELOG/DEVPLAN 阶段和工具数已落后当前提交；CI 以静态检查为主，本次没有独立构建 HAP 或重跑物理设备 E2E。

2. 基线与产品范围

深开鸿仓库审计提交：d98d48da33d1782b3dc24f07c83e58012d13868b（2026-10-26 23:12（台北时间））。上游 main 审计提交：10caad1d8d575cafe765b8e94e95f51ef0a4a744（2026-10-27 00:38（台北时间））。

上游同一仓库有两个产品：BrowserOS neo 是被外部 AI agent 驱动的第二浏览器；BrowserOS main 是基于 Chromium 的日常浏览器并内置 AI assistant。深开鸿 UPSTREAM_BASELINE.md 主要声明对标 Neo。本报告以 Neo 为主线，另把 BrowserOS main-only 能力标记为扩展范围，避免混算完成度。

状态分类：已实现（有代码/仓库证据）、部分实现、缺失/桩代码、平台限制、待设备验证、文档过期或有意差异。源码审计不能替代实际构建/实机验收。

3. 子系统判定

子系统	当前判定	代码级解释
浏览器壳 / ArkWeb	基本完成（平台等价）	真实 Web 组件、标签/导航/历史/书签等已存在；不是 Chromium 内核同等复刻。
12 屏 UI	历史截图覆盖较高；当前主线待重新比对	需要将当前 Neo redesign 纳入视觉与交互 diff，不能靠页面数量判断。
内置 Agent	基础链路完成、能力部分对齐	15 步循环、SSE/回退、工具执行和状态有实现；内置工具约 9 个，Provider 主要为 OpenAI-compatible。
MCP	名称覆盖高，语义/协议/隔离不足	17 个工具名、HTTP/WS 服务和限流存在；upload/pdf/windows/tab_groups/session handling 仍有明显差距。
一键 Harness 接入	未完成	检测器 stub、配置写到 App 沙盒、UI copy

子系统	当前判定	代码级解释
		JSON；尚非写入宿主配置并握手。
登录态 / 密码	部分完成且有安全风险	手动 Cookie/Bitwarden 导入有实现；Chrome profile 路径和 cookie/localStorage 读取是空实现。
Audit / Replay	基础截图回放，不等于 rrweb	定时 screenshot 和内部 Agent 日志存在；外部 MCP 工具调用的审计接线和 DOM replay 缺失/待实现。
交付质量	有项目内设备证据，release gate 不完整	云端 CI 主要静态检查；生产签名和真实设备矩阵仍需正式门禁。

4. 最高优先级的缺口

优先级	缺口	最低动作
P0	MCP Session/Tab ownership 与并发隔离	把 MCP session ID 真正用于后续路由；按 session/profile/tab/generation 绑定目标，避免多个 harness 串页。
P0	密码库活动存储与明文导出	Preferences 的 JSON 是活动读取来源；导出 encrypted:false。先做加密迁移和安全擦除。
P0	敏感工具参数落入 OperationLog	AgentEngine 截断后记录 raw args；对 password/OTP/API key 和 `type/fill` 进行写入前脱敏。
P0	Harness 检测/一键安装	checkToolInstalled() 直接 false，配置写入沙盒；实现真实 adapter、备份、原子合并与握手。
P1	MCP 协议版本和 Streamable HTTP	支持现代协议协商并补 session lifecycle/notifications；统一 /mcp endpoint。
P1	upload/pdf/windows/tab_groups 功能语义	实现受支持的真实行为；无法支持项必须能力声明/不暴露，不保留假成功入口。
P1	Chrome 登录态导入	完善受平台许可的数据导入向导；直接 profile import 若不可行须明确限制。
P1	Audit 与真实回放	将外部 MCP tool call 写入 ledger；评估并实现 DOM 事件回放，或诚实命名截图时间线。
P1	Profile targeting 和当前 upstream 视觉差异	维护单独的上游 baseline，补 session/profile/tab group 的行为和视觉回归。
P1	构建/设备/发布质量门禁	把构建、MCP conformance、安全 canary、API14/API23 smoke 和生产签名纳入 release gate。

5. 关键源码证据

证据点	源码位置	审计判定
Harness auto-detect	ConnectionManager.ets:174-185	checkToolInstalled() return false；

证据点	源码位置	审计判定
		writeMCPConfig() 保存 connections/<tool>_mcp.json 到应用沙盒。
MCP protocol	McpJsonRpcCore.ets:141-160	initialize protocolVersion 为 2024-11-05；生成 Session ID/header，但需补后续 session ownership。
Unsupported tools	McpJsonRpcCore.ets:281-306	upload/pdf 明确 unsupported；windows 仅 list。
Chrome login import	LoginStateManager.ets:240-248	detectChromeDataPath 返回 null；readChromeCookies/localStorage 返回空数据。
Credential vault	CredentialStore.ets:205-250	Bitwarden 导出 encrypted:false；persist() 将 JSON 写入 Preferences，Asset Store 另有镜像。
Sensitive operation log	AgentEngine.ets:536-543	OperationLog 写入 function_args 前 60 字符与结果前 100 字符，需要先脱敏。
Replay approach	SessionManager.ets:290-317；ScreenshotCapture.ets	Session 定时截图捕获，和上游 rrweb event stream / page replay 不同。
MCP endpoint drift	ConnectionManager.ets:169-185；HttpMcpTransport.ets	配置生成 /sse；HTTP 服务实际处理 POST /mcp，GET /mcp 返回 405。
Document drift	README.md / CHANGELOG.md / DEVPLAN.md	README 仍写 10 MCP tools/P1-P40，CHANGELOG 最新 P40，DEVPLAN 有 P43 与之后提交不一致。

6. P51-P56 路线与验收闸门

阶段	目标	交付
P51	安全与 session 正确性	MCP SessionStore / tab ownership / profile target；AuditRedactor；凭据加密迁移；并发 E2E。
P52	MCP 协议与真实一键连接	2026-07-28+legacy negotiation；Streamable HTTP；7 个 harness adapter；配置备份/原子写/rollback/health-check。
P53	登录态与浏览器能力	正式 cookie/password import wizard；profile isolation；upload/pdf；API14/API23 下载验证。
P54	Audit / Replay	统一内部 Agent 与外部 MCP 事件；全量 audit list；rrweb-like replay feasibility；敏感脱敏/磁盘恢复。
P55	行为等价	稳定 SnapshotRef/act；完整 tab groups；profile targeting；当前 upstream visual diff。
P56	工程化发布	构建/协议/安全/视觉/设备门禁；正式签名/迁移/回滚；文档和仓库清理。

7. 如何使用详细差距矩阵

随附 CSV 共 99 条核对项，包含 ID、范围、模块、状态、优先级、上游依据、深开鸿代码/证据、风险、建议动作与验收标准。优先从 P0 项过滤开始，再按 P1 模块执行。

不要把“已实现（有代码/证据）”解释为本次重新运行的 PASS；本次未运行 HAP build 和真实物理设备 E2E。仓库里既有 evidence/log 是项目自己记录的验证，报告将其作为辅助材料，并把没有独立实测的项目标记为待验收。

8. 源码与文档链接

- Deep repo: https://github.com/swsgbl/BrowserOS-KaihongOS/tree/d98d48da33d1782b3dc24f07c83e58012d13868b
- Upstream repo: https://github.com/browseros-ai/BrowserOS/tree/10caad1d8d575cafe765b8e94e95f51ef0a4a744
- Deep MCP server: https://github.com/swsgbl/BrowserOS-KaihongOS/tree/d98d48da33d1782b3dc24f07c83e58012d13868b/blob/d98d48da33d1782b3dc24f07c83e58012d13868b/entry/src/main/ets/service/MCPServer.ets
- Deep MCP JSON-RPC: https://github.com/swsgbl/BrowserOS-KaihongOS/tree/d98d48da33d1782b3dc24f07c83e58012d13868b/blob/d98d48da33d1782b3dc24f07c83e58012d13868b/entry/src/main/ets/service/McpJsonRpcCore.ets
- Deep ConnectionManager: https://github.com/swsgbl/BrowserOS-KaihongOS/tree/d98d48da33d1782b3dc24f07c83e58012d13868b/blob/d98d48da33d1782b3dc24f07c83e58012d13868b/entry/src/main/ets/service/ConnectionManager.ets
- Deep CredentialStore: https://github.com/swsgbl/BrowserOS-KaihongOS/tree/d98d48da33d1782b3dc24f07c83e58012d13868b/blob/d98d48da33d1782b3dc24f07c83e58012d13868b/entry/src/main/ets/service/CredentialStore.ets
- Upstream Neo README: https://github.com/browseros-ai/BrowserOS/tree/10caad1d8d575cafe765b8e94e95f51ef0a4a744/blob/10caad1d8d575cafe765b8e94e95f51ef0a4a744/README.md
- Upstream BrowserOS README: https://github.com/browseros-ai/BrowserOS/tree/10caad1d8d575cafe765b8e94e95f51ef0a4a744/blob/10caad1d8d575cafe765b8e94e95f51ef0a4a744/README.BrowserOS.md
- Upstream MCP registry: https://github.com/browseros-ai/BrowserOS/tree/10caad1d8d575cafe765b8e94e95f51ef0a4a744/blob/10caad1d8d575cafe765b8e94e95f51ef0a4a744/packages/browseros-agent/packages/browser-mcp/src/tools/registry.ts
- Upstream Replay docs: https://github.com/browseros-ai/BrowserOS/tree/10caad1d8d575cafe765b8e94e95f51ef0a4a744/blob/10caad1d8d575cafe765b8e94e95f51ef0a4a744/docs/neo/audit-and-replay.mdx
- Upstream MCP docs: https://github.com/browseros-ai/BrowserOS/tree/10caad1d8d575cafe765b8e94e95f51ef0a4a744/blob/10caad1d8d575cafe765b8e94e95f51ef0a4a744/docs/neo/mcp/index.mdx